

Essential Fraud Readiness Review

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Bokamoso Skills Institute

Report reference RPT-MKFRS-V12-COMP-BOKAMOSO-V1
Generated 23 August 2026
Essential package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	3
What the result means	4
Domain overview	7
Priority findings, contradictions and scenarios	8
Priority risks	13
Leadership decisions and roadmap	16
Proof requirements	20
Methodology, limitations and next steps	21
Appendix: supporting material	22
Complete supporting detail	22
E1. Supporting control actions	22
E2. Definitions and score basis	28

Executive summary

Systemic foundational control gap.

Reported readiness

30

out of 100

Reactive

Overall readiness position

The assessment places Bokamoso Skills Institute at 30.12/100 with Reactive maturity. This score indicates a programme that has some designed elements but remains largely reactive to fraud risk rather than operating through repeatable, sustained controls and governance. Management's own responses record a comparatively stronger, self-reported position in Digital and Identity Fraud Risk (the highest domain score reported), while governance, risk identification, detection capability, incident response and reporting culture show materially lower self-assessed positions. The assurance boundary for this assessment is that it reflects management's responses and the MK scoring method; it is strategic fraud-risk analysis and control design, not independent verification of operating effectiveness.

What is shaping the readiness position

Four connected themes shape the reported position. First, fraud governance and risk-management discipline is incomplete: process-level fraud mapping and accountable treatment are missing or only partly designed, which constrains prioritisation and funded remediation. Second, monitoring, escalation and detection coverage are informal and reactive in areas, so anomalous digital or transactional activity can persist without timely triage. Third, incident response and evidence integrity are not consistently established, so suspected matters lack a defined preservation and custody route. Fourth, supplier and payment integrity controls are partly designed, leaving supplier onboarding and bank-detail change verification vulnerable. Together these themes create a pattern where ownership, detection and containment are disconnected, producing the reactive maturity reading.

What this means for management

Management should treat the assessed position as a focused work plan: a comparatively stronger self-reported position in digital and identity risk provides a starting point, but that reported strength does not by itself prove operating readiness. The immediate implication is to prioritise establishing accountable ownership and a repeatable governance and reporting cadence, shore up monitoring and analytics so exceptions are triaged and escalated, and put basic evidence-preservation and supplier-verification steps in place. These actions convert the score into a practical operating programme rather than leaving gaps that allow exposure to persist.

COVERAGE

100%

CRITICAL GAPS

12

MAJOR GAPS

4

Assessment scope and limitations

APPLICABLE CONTROLS

67

CONTROL VISIBILITY

100%

EXCLUDED AREAS

1

UNCERTAINTY RESPONSES

0

The result reflects the control areas applicable to the organisation. Valid scope exclusions and oversight-routed controls are part of the adaptive assessment design; differences in assessed scope

may limit direct comparison with other assessments.

The aggregate result and its ten underlying domains

The Reactive result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.

Fraud Leadership and Governance 22 Reactive	Fraud Risk Identification 22 Reactive	Operational Fraud Controls 41 Developing	Fraud Detection Capability 21 Reactive	Fraud Incident Response 24 Reactive
Whistleblowing and Reporting Culture 21 Reactive	Third-Party and Supply Chain Fraud Risk 42 Developing	Digital and Identity Fraud Risk 46 Developing	Fraud Culture and Awareness 37 Reactive	Continuous Improvement and Fraud Risk Monitoring 21 Reactive

What the result means

The recorded conditions requiring first attention

CRITICAL CONTROL GAP · FRAUD LEADERSHIP AND GOVERNANCE

A named senior owner is accountable for fraud risk management and has authority to drive action.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD LEADERSHIP AND GOVERNANCE

Management owns fraud-risk decisions and control action.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · CONTINUOUS IMPROVEMENT AND FRAUD RISK MONITORING

The organisation periodically reviews its fraud risks and control environment.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD RISK IDENTIFICATION

The organisation has completed a structured fraud risk assessment within the past two years.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

Supplier onboarding verifies business identity, ownership and initial banking information before approval.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD INCIDENT RESPONSE

The organisation has a documented process for responding to suspected fraud incidents.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD INCIDENT RESPONSE

Evidence linked to suspected fraud is identified, preserved and handled appropriately.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · WHISTLEBLOWING AND REPORTING CULTURE

The organisation provides a confidential or anonymous channel for reporting suspected fraud or misconduct.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

Where a strong average can still hide a real gap

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD LEADERSHIP AND GOVERNANCE

A named senior owner is accountable for fraud risk management and has authority to drive action.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Management response: see the leadership roadmap section for accountable executive mandates, escalation authority and the fraud-risk implementation and control-effectiveness review cadence.

MATURITY CEILING · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD LEADERSHIP AND GOVERNANCE

Core domain Fraud Leadership and Governance scored below 40.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Management response: see the leadership roadmap section for accountable executive mandates, escalation authority and the fraud-risk implementation and control-effectiveness review cadence.

Core domain Fraud Leadership and Governance scored below 60.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Management response: see the leadership roadmap section for accountable executive mandates, escalation authority and the fraud-risk implementation and control-effectiveness review cadence.

A domain score is an average. It can still contain one specific control that is materially weaker than the others feeding into the same number. The purpose of this report is to surface that unevenness so leadership does not treat the overall score as a substitute for control-level attention.

DOMAIN OVERVIEW

Domain overview

The systemic pattern

The organisation's self-assessment exposes a single, enabling pattern: gaps in ownership and process-level risk discipline have propagated into detection, supplier controls and incident handling. A partly designed senior fraud-risk accountability arrangement and an absence of process-level fraud mapping mean that critical fraud scenarios are not consistently assigned to a named control owner. Where monitoring and analytics are informal, alerts and anomalous events do not reliably flow into a controlled triage and escalation route, permitting unusual activity to avoid timely challenge. When a suspected matter is raised, evidence-preservation and custody arrangements are not in place, increasing the risk that records needed for containment or investigation are incomplete or weakened. Finally, supplier onboarding and bank-detail verification are only partly designed, creating a route by which payment instructions could be redirected before independent challenge. These issues are tightly connected: incomplete governance prevents consistent fraud maps being produced; absent maps limit the ability to define meaningful detection coverage; weak detection leaves incidents dependent on ad hoc reporting; and without custody discipline incidents cannot be contained or turned into durable learning.

Every assessed domain is summarised below. Individual domain narratives are omitted because the recorded condition is systemic rather than domain-specific.

DOMAIN	WEIGHT	SCORE	CONTROLS IN SCOPE	PARTIALLY DESIGNED OR BELOW
Fraud Leadership and Governance	12%	22/100	7	7
Fraud Risk Identification	12%	22/100	8	8
Operational Fraud Controls	14%	41/100	10	7
Fraud Detection Capability	14%	21/100	8	8
Fraud Incident Response	10%	24/100	5	5

DOMAIN	WEIGHT	SCORE	CONTROLS IN SCOPE	PARTIALLY DESIGNED OR BELOW
Whistleblowing and Reporting Culture	6%	21/100	5	5
Third-Party and Supply Chain Fraud Risk	10%	42/100	7	5
Digital and Identity Fraud Risk	12%	46/100	9	4
Fraud Culture and Awareness	5%	37/100	4	3
Continuous Improvement and Fraud Risk Monitoring	5%	21/100	4	4

PRIORITY FINDINGS, CONTRADICTIONS AND SCENARIOS

Priority findings, contradictions and scenarios

6 conditions were selected for executive attention from 43 recorded findings. The complete register of all 43 findings is provided in the Essential Supporting Register (RPT-MKFRS-V12-COMP-BOKAMOSO-V1-supporting-register.xlsx).

Role distinction: Control owner identifies the role responsible for implementing or operating the control. Accountable executive identifies the executive role responsible for sponsorship, decision rights and escalation. The two roles may legitimately differ.

Value diversion through supplier and payment processes

Supplier onboarding and payment-instruction verification are partly designed. Without a complete pre-activation checklist, independent registration and bank-ownership verification, and a second reviewer before vendor activation, the vendor population and any late bank-detail changes present an exposure where value can be redirected through fictitious or compromised supplier relationships. The immediate management test is independent verification before a supplier or bank change takes effect; absent that independent challenge, this supplier-to-payment pathway remains exposed.

Weak challenge at identity, transaction and sensitive-change points

Digital access and transactional monitoring are reported as informal or reactive, and analytics and rule-based detection lack a maintained catalogue and tuning discipline. Where identity verification and sensitive-change controls are informal, unusual login, profile or transaction patterns and threshold-adjacent activity risk remaining unchallenged. The completion test for this exposure is a defined monitoring cycle with named exception review and evidence retention for dispositions; without that, suspicious activity is likely to persist without timely escalation.

Limited containment and learning after suspected fraud

Evidence preservation and chain-of-custody capability are reported as not in place. When suspected matters occur, absence of a defined intake, custody and integrity-check process means records can be lost, altered or become difficult to use for investigation or recovery. The management completion test is a defined intake and preservation route at first report, with trained custodians and an evidence register; without such a route, containment and organisational learning will remain limited.

Fraud Risk Identification: Fraud risks are mapped to the organisation's important processes.

DOMAIN

Fraud Risk Identification

DIAGNOSIS

Process-level fraud risk mapping was self-assessed as "Not in place" (The capability is absent or is not recognised as required; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Fraud risks are mapped to the organisation's important processes. — Not in place

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Risk / compliance accountable owner with named process owners

IMPLEMENTATION

Moderate difficulty · 90 days

Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

DOMAIN

Fraud Incident Response

DIAGNOSIS

Fraud evidence preservation and chain of custody was self-assessed as "Not in place" (The capability is absent or is not recognised as required; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Evidence linked to suspected fraud is identified, preserved and handled appropriately. — Not in place

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Investigation lead / Evidence custodian

IMPLEMENTATION

High difficulty · 60 days

Digital and Identity Fraud Risk: The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel.

DOMAIN

Digital and Identity Fraud Risk

DIAGNOSIS

Suspicious digital-activity monitoring was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel. — Informal / reactive

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Security monitoring / the security monitoring function

IMPLEMENTATION

High difficulty · 90 days

Fraud Leadership and Governance: A named senior owner is accountable for fraud risk management and has authority to drive action.

DOMAIN

Fraud Leadership and Governance

DIAGNOSIS

Senior fraud-risk ownership was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

A named senior owner is accountable for fraud risk management and has authority to drive action. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Named fraud-risk executive

IMPLEMENTATION

Low difficulty · 30 days

Fraud Detection Capability: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

DOMAIN

Fraud Detection Capability

DIAGNOSIS

Analytics and rule-based detection was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions. — Informal / reactive

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Fraud analytics owner

IMPLEMENTATION

High difficulty · 90 days

Operational Fraud Controls: Supplier onboarding verifies business identity, ownership and initial banking information before approval.

DOMAIN Operational Fraud Controls	ASSESSED CONTROL STATE Supplier onboarding verifies business identity, ownership and initial banking information before approval. — Partly designed
DIAGNOSIS Supplier-onboarding verification was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.	WHY IT MATTERS This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.
RECOMMENDED CONTROL Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.	CONTROL OWNER Procurement / Vendor Master
ACCOUNTABLE EXECUTIVE Finance / operations accountable owner	IMPLEMENTATION Moderate difficulty · 60 days
REMAINING LIMITATION Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.	

Contradictions

No material contradiction was detected.

Independent evidence remains necessary to validate the reported control position.

Scenarios and assurance tests

Conditional exposure pathways

The following pathways are conditional tests management can use to validate prevention, detection and containment.

- UNUSUAL ACTIVITY AVOIDS TIMELY CHALLENGE BECAUSE MONITORING OR ESCALATION COVERAGE IS INCOMPLETE**
This pathway begins when an unusual refund, credit or manual adjustment falls outside expected patterns and the monitoring regime does not include a rule or an assigned reviewer for that pattern. The current environment fails where monitoring activity is informal, exception ownership is not evidenced, and alerts are not triaged within an agreed SLA. Warning indicators include repeated low-value or threshold-adjacent adjustments, a growing backlog of unassigned alerts, or a monitoring rule left unexecuted for a full cycle. Immediate containment requires assigning and triaging affected alerts, preserving the relevant activity records, and escalating any overdue items. A longer-term response is to define monitoring coverage, red flags, review ownership, closure evidence and threshold-change governance so similar patterns are detected and resolved in future.
- RECORDS OR REPORTING ARE WEAKENED AFTER A SUSPECTED FRAUD MATTER, ALLOWING EXPOSURE TO REPEAT**
This pathway can begin when a suspected matter originates at a distributed operating location and records remain local rather than being preserved under controlled custody. The environment fails where evidence preservation and custody processes are ad hoc. Warning indicators include a report routed through a channel controlled by the implicated process, relevant records unavailable at escalation, or an overdue severity/containment decision. Immediate containment is to open an incident record, preserve relevant records under controlled custody and assign a named containment and investigation owner. Longer-term response requires protected reporting, severity-based escalation, documented evidence-preservation procedures and a repeat-exposure review to turn cases into programme-level learning.
- SUPPLIER OR PAYMENT INSTRUCTION IS DIVERTED THROUGH A COMPROMISED OR FICTITIOUS RELATIONSHIP**
This pathway starts when a supplier is activated or a bank-detail change is submitted shortly before payment and the vendor activation or change is not independently verified. The environment fails where procurement's pre-activation checklist,

independent registration and bank-ownership verification, and second-reviewer sign-off are incomplete. Warning indicators include a new or reactivated supplier before independent verification, a bank-detail change immediately before payment, or an urgent payment request that bypasses the usual callback or verification route. Immediate containment is to pause the affected supplier or payment instruction, independently confirm the trusted beneficiary details and preserve the approval trail. The longer-term response is to implement independent supplier and bank-detail verification, dual approval before activation or payment, and complete population monitoring.

PRIORITY RISKS

Priority risks

Risk priority is produced by the MK qualitative likelihood/impact matrix. Risks sharing the same priority class are not more finely ranked by their display order. Likelihood and impact are qualitative descriptors, not statistical probabilities. The complete risk register (42 risks) is provided in the Essential Supporting Register (RPT-MKFRS-V12-COMP-BOKAMOSO-V1-supporting-register.xlsx).

RISK 1 · FRAUD RISK IDENTIFICATION

CRITICAL

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner.

Because the self-assessment records "Fraud risks are mapped to the organisation's important processes" as "Not in place"; the expected control standard is therefore not yet met, there is a risk that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner. Consequence pathway: Material process exposures can remain without explicit control ownership or treatment; Unmapped process-level fraud routes can leave value diversion or loss outside targeted controls.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Risk Identification: Not in place — The capability is absent or is not recognised as required

REQUIRED TREATMENT

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

90 days

RISK 2 · FRAUD DETECTION CAPABILITY

CRITICAL

As transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation.

Because the self-assessment records "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that as transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Detection Capability: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

TARGET PERIOD

90 days

RISK 3 · DIGITAL AND IDENTITY FRAUD RISK

CRITICAL

Digital account compromise or misuse is not detected promptly

Because material login, access, profile and transaction events are not completely monitored and triaged, there is a risk that a compromised or malicious identity uses digital channels without timely detection and response. Consequence pathway: customers and partners lose trust in digital channels; digital operations must contain and investigate a wider incident; security or personal-data notification duties may arise; unauthorised transactions or account changes cause direct loss.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Digital and Identity Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

TARGET PERIOD

90 days

RISK 4 · FRAUD INCIDENT RESPONSE

CRITICAL

Fraud evidence loses integrity or chain of custody

Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Fraud Incident Response: Not in place — The capability is absent or is not recognised as required

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

IMPACT

High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

TARGET PERIOD

60 days

RISK 5 · OPERATIONAL FRAUD CONTROLS

CRITICAL

Fictitious or conflicted supplier enters the vendor population

Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

TARGET PERIOD

60 days

RISK 6 · FRAUD LEADERSHIP AND GOVERNANCE

HIGH

Fraud-risk accountability and escalation failure

Because executive fraud-risk accountability, authority and escalation are not supported by the required operating evidence, there is a risk that material fraud-control gaps remain unresolved or accepted without an authorised decision. Consequence pathway: cross-functional actions remain ownerless or overdue; leadership may be unable to demonstrate active stewardship of known fraud risks; losses continue because required resources or corrective action are delayed.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Leadership and Governance: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The CEO must approve a fraud-risk RACI that gives management clear decision rights, action ownership and resource authority, while the Governing body / independent oversight or equivalent assurance function receives independent review reports and tracks overdue control action to closure. The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

TARGET PERIOD

30 days

LEADERSHIP DECISIONS AND ROADMAP

Leadership decisions and roadmap

Target control environment

Strengthen fraud-risk identification and treatment

Management should close the gap where fraud risks are not mapped to material processes by producing a process-by-process fraud map covering every value-bearing process. Each map must record the fraud scenarios, the roles and system permissions able to execute them, the preventive and detective controls relied upon, and the residual gap. Process owners must sign their own maps, and any process without a mapped control owner escalates to the fraud-risk executive. The completion test is that 100% of material value-bearing processes have a signed fraud map with named controls and residual gaps; this response is owned by the finance/operations accountable executive with risk/compliance and named process owners executing the mapping.

Strengthen supplier onboarding and identity checks

Procurement and the vendor-master function must implement a pre-activation checklist for every proposed supplier, independently verify legal registration and bank ownership, screen beneficial owners and conflicts, apply a risk-rating, and block ERP activation until a second reviewer signs. The vendor master must retain the evidence package. The completion test is that 100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval. This design interrupts the supplier-to-payment diversion exposure by ensuring payments are released only after independent verification.

Strengthen monitoring, exception review and escalation

Material processes need defined monitoring coverage, documented red flags and a named reviewer assignment with SLAs. Detection design should be formalised into an operating model that assigns accountable executives, identifies in-scope event feeds, maintains a monitoring-rule catalogue, and records alert-case dispositions and tuning activity. The organisation-level decision framework should approve accountable executive mandates, require remediation rather than passive acceptance for Critical and High risks, set the control-design standard to be used, allocate resource for specialist work where required, and endorse prerequisite-first sequencing for dependent improvements so foundational elements are delivered first.

TARGET CONTROL RESPONSE

For digital and identity monitoring, the security-monitoring owner must inventory material login, privilege, profile and transaction events, implement risk rules across the complete in-scope event feed, assign alerts to trained analysts, preserve dispositions and escalate high-risk account compromise immediately. Rules must be tuned monthly using confirmed true and false positives. The interruption point for the monitoring-and-escalation exposure is defined coverage and timely triage: all priority event feeds are monitored and 95% of high-risk alerts triaged within SLA.

TARGET CONTROL RESPONSE

For analytics and rule-based detection, the fraud-analytics owner must maintain a rule catalogue where every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role. Tests should include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering. Results must reconcile to source control totals and rules are tuned monthly from confirmed true and false positives. The completion test is that every priority fraud scenario has at least one operating data check with monthly tuning completed.

Strengthen evidence preservation and custody

Every material suspected matter must follow a defined intake and evidence-preservation process from the moment it is raised. The investigation lead must open an evidence register, trained custodians identify sources, create forensic copies or sealed originals, record hashes or seal numbers and every transfer, store evidence in an access-controlled repository and escalate any custody break immediately to Legal. Proof of completion is that 100% of sampled material-case evidence has a complete custody trail and matching integrity check. This response interrupts the repeat-exposure pathway by ensuring records are available, attributable and usable for containment, investigation and recovery.

Strengthen fraud-risk ownership and oversight

Senior accountability must be explicit and operational. The CEO should issue a dated fraud-risk accountability mandate naming one executive with delegated decision rights and budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions. Governance must receive regular packs and an overdue-action escalation log to confirm remedial progress. The completion test is that 100% of material fraud actions have a funded owner and due date, with overdue items escalated within 30 days. This governance response connects the control design and monitoring improvements to executive decision routes, preventing workstreams from remaining ownerless.

Leadership decisions required

Every decision below carries a defined accountable executive role and a fixed target period; each is grounded in the material findings, risks and controls set out in this report and in the complete registers in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-BOKAMOS0-V1-supporting-register.xlsx).

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	CEO / Managing Director	30 days	Known risk pathways remain untreated without a documented acceptance basis.
3	Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	30 days	Partial or inconsistent designs fail to address the causal pathway.
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Finance / operations accountable owner	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Approve the prerequisite sequence and escalate threatened prerequisites.	CEO / Managing Director	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	CEO / Managing Director	60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

Foundational control programme

Establishing a control baseline, in dependency order. Each step names the exact control requiring establishment or strengthening.

STEP	DOMAIN	CONTROL TO ESTABLISH	ACCOUNTABLE OWNER	TARGET
1	Fraud Risk Identification	Fraud risks are mapped to the organisation's important processes.	Finance / operations accountable owner	90 days
2	Fraud Incident Response	Evidence linked to suspected fraud is identified, preserved and handled appropriately.	Legal / investigations accountable owner / Finance / operations accountable owner	60 days
3	Digital and Identity Fraud Risk	The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel.	Technology / security accountable owner	90 days
4	Fraud Leadership and Governance	A named senior owner is accountable for fraud risk management and has authority to drive action.	CEO / Managing Director	30 days
5	Fraud Detection Capability	Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.	Finance / operations accountable owner / Technology / security accountable owner	90 days
6	Operational Fraud Controls	Supplier onboarding verifies business identity, ownership and initial banking information before approval.	Finance / operations accountable owner	60 days

30/60/90-day roadmap

The first 30 days establish decisions and ownership; the 60- and 90-day windows implement and evidence the linked controls.

By 30 days — Stabilise

In the first 30 days stabilise governance and incident baselines. Approve the fraud-risk mandate, reporting rhythm, escalation authority and decision record so there is a clear route for ownership and overdue-action escalation. At the same time, publish a short incident-intake and evidence-preservation instruction so suspected matters are routed into a basic custody process immediately rather than remaining local or ad hoc. Proof of completion is a signed executive accountability mandate, the first governance pack or equivalent and an overdue-action escalation log.

First 30 days — decisions and foundations

PRIORITY DECISION	DELIVERABLE	ACCOUNTABLE EXECUTIVE	COMPLETION TEST
Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	Signed mandate names each accountable executive, decision rights and the escalation route.
Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	CEO / Managing Director	Decision recorded, accountable owner confirmed and escalation route documented.
Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	Approved control-improvement baseline records the required design standard and any authorised deviations.
Approve prerequisite-first sequencing for dependent improvements.	Approve the prerequisite sequence and escalate threatened prerequisites.	CEO / Managing Director	Dependency sequence is approved with named prerequisite owners and escalation for threatened dependencies.

First 30 days — implementation foundations

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Leadership and Governance	Implement the target control design for Fraud Leadership and Governance. Escalation trigger: Any material control action without an owner or more than 30 days overdue.	CEO / Managing Director	100% of material fraud actions have a funded owner and due date, with overdue items escalated within 30 days.
Fraud Incident Response	Implement the target control design for Fraud Incident Response. Escalation trigger: Severe incident not escalated within four hours or annual tabletop overdue.	Finance / operations accountable owner / Legal / investigations accountable owner	All incidents receive a severity decision within four hours and annual tabletop actions close by due date.

By 60 days — Establish

By day 60 establish the highest-priority preventive and containment controls. Put in place evidence-preservation processes with an evidence register, chain-of-custody forms, repository access controls and retention/legal-hold instructions so sampled cases have intact custody trails. Approve resource allocation for specialist or complex control delivery where required and confirm the sequencing approach so prerequisites are resolved before dependent control work begins. Completion is shown by custody and preservation artifacts for test cases and a resource-confirmed delivery plan for complex workstreams.

60-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Incident Response	Implement the target control design for Fraud Incident Response. Escalation trigger: Any unexplained custody gap, integrity mismatch or unauthorised repository access.	Legal / investigations accountable owner / Finance / operations accountable owner	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any supplier activated before verification or any ownership/conflict match unresolved.	Finance / operations accountable owner	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.

By 90 days — Operate and review

Between days 31 and 90 operate the monitoring and detection improvements and report measurable progress. Refresh the structured fraud-risk assessment, map process pathways and assign treatment owners so per-process fraud maps are available across material value-bearing processes. Define monitoring coverage, red flags, review ownership, closure evidence and overdue escalation so alert-case records, a monitoring-rule catalogue and monthly tuning reports exist. Consolidate progress into the governance packs and confirm that the agreed cadence of monthly implementation reporting and quarterly control-effectiveness review is operating. Success is demonstrated by the completed process fraud maps, monitoring execution logs and custody proofs where applicable.

90-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Risk Identification	Implement the target control design for Fraud Risk Identification. Escalation trigger: Any material process unmapped, or a mapped residual gap with no owner.	Finance / operations accountable owner	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
Digital and Identity Fraud Risk	Implement the target control design for Digital and Identity Fraud Risk. Escalation trigger: Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated.	Technology / security accountable owner	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.
Fraud Detection Capability	Implement the target control design for Fraud Detection Capability. Escalation trigger: A priority scenario with no operating check, or rules unexecuted for a full cycle.	Finance / operations accountable owner / Technology / security accountable owner	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.

Management conclusion

The assessment records a Reactive maturity with specific, connected gaps across governance, risk identification, detection, incident response and third-party controls. There is a comparatively stronger reported position in Digital and Identity Fraud Risk, which provides a location to focus monitoring and analytic improvements, but that reported strength does not substitute for process-level mapping, accountable ownership or evidence-preservation discipline. Management's immediate priorities are to stabilise executive accountability and incident intake, establish supplier verification and detection rules, and operate a visible 30/60/90 delivery rhythm so control improvements are owned, evidenced and escalated where overdue. The assessed position is a starting point for management attention: parts of the profile report relative strength, while other capabilities need to be connected into an owned, repeatable operating model.

PROOF REQUIREMENTS

Proof requirements

The items below are the immediate proof requirements linked to the priority findings above. The complete evidence checklist is not reproduced in this report; it is provided in full in the companion

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Control linkage showing preventive and detective controls	Whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable.	Risk / compliance accountable owner with named process owners	Not yet requested
2	Per-process fraud scenario map	Whether each material process has explicit fraud scenarios, relevant roles or permissions and residual exposure documented.	Risk / compliance accountable owner with named process owners	Not yet requested
3	Process inventory identifying material value-bearing processes	Whether the complete population of material value-bearing processes has been identified before fraud-risk mapping is assessed.	Risk / compliance accountable owner with named process owners	Not yet requested
4	Process-owner sign-off	Whether process owners have reviewed and accepted the mapped fraud scenarios, control ownership and residual gaps.	Risk / compliance accountable owner with named process owners	Not yet requested
5	Chain-of-custody forms	Whether each transfer of material evidence records custody, timing and handover without unexplained gaps.	Investigation lead / Evidence custodian	Not yet requested
6	Evidence register	Whether all material evidence items are uniquely recorded, assigned and traceable through the case.	Investigation lead / Evidence custodian	Not yet requested
7	Hash or seal records	Whether collected evidence has integrity markers that can be matched at later custody points.	Investigation lead / Evidence custodian	Not yet requested
8	Repository access log	Whether access to preserved evidence is restricted, attributable and reviewable.	Investigation lead / Evidence custodian	Not yet requested
9	Retention/legal-hold instruction	Whether preservation instructions define the required retention or legal-hold treatment for relevant records.	Investigation lead / Evidence custodian	Not yet requested
10	Alert case records	Whether suspicious digital-activity alerts are assigned, investigated, dispositioned and escalated to the required service level.	Security monitoring / the security monitoring function	Not yet requested
11	In-scope event inventory	Whether the complete population of priority login, access, profile and transaction events has been identified for monitoring.	Security monitoring / the security monitoring function	Not yet requested
12	Monitoring-rule catalogue	Whether monitoring rules are defined, linked to fraud scenarios, assigned to a reviewing role and maintained through controlled tuning.	Security monitoring / the security monitoring function	Not yet requested
13	Monthly tuning and coverage report	Whether priority event feeds were monitored for the stated period, high-risk alerts were triaged to the required service level, coverage gaps were recorded and rule tuning was completed from confirmed outcomes.	Security monitoring / the security monitoring function	Not yet requested
14	Last two fraud-risk governance packs	Whether sufficient, attributable evidence is present in the last two fraud-risk governance packs to test the linked control across the complete in-scope population for the stated period.	Named fraud-risk executive	Not yet requested
15	Overdue-action escalation log	Whether sufficient, attributable evidence is present in the overdue-action escalation log to test the linked control across the complete in-scope population for the stated period.	Named fraud-risk executive	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue items. Every item begins with the status "Not yet requested"; status changes require a separately scoped review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity ceilings and advisory model use only the recorded assessment inputs and the MK Fraud Readiness methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain the

specified operating proof before treating a control as effective or a finding as resolved.

Control design standard. Priority controls are specified by responsibility, population or scope, operating frequency, retained evidence, independent challenge, escalation trigger, service level, effectiveness measure and response to failure.

Companion register. The complete Essential delivery includes the Essential Supporting Register (RPT-MKFRS-V12-COMP-BOKAMOSO-V1-supporting-register.xlsx). It carries the complete finding, risk, control-action, evidence, roadmap and question-trace registers that are intentionally bounded in this PDF.

Assessment basis: submitted self-assessment responses and the MK Fraud Readiness methodology.

Recommended next step. Commission independent validation of the control linkage showing preventive and detective controls. Confirm whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable. This is the immediate proof priority; the complete sequence is set out in Proof requirements above and the full checklist in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-BOKAMOSO-V1-supporting-register.xlsx).

APPENDIX

Appendix: supporting material

Bounded supporting material for the priority matters above. The complete authoritative registers are provided in the supporting register, not reproduced here.

Complete supporting detail

This report presents the highest-priority matters from a complete assessment inventory of 68 controls (67 applicable and 1 excluded). The full assessment identified 43 material findings, 42 risks, 43 control improvements, 176 evidence artefacts, 43 recommended actions and 94 functional-agenda items.

Every item not shown in this report is retained in full in the Essential Supporting Register (RPT-MKFRS-V12-COMP-BOKAMOSO-V1-supporting-register.xlsx). No identified weakness has been discarded.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Fraud Detection Capability	Close the material control weakness recorded for "The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags".	The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the management fraud-risk review route.	Finance / operations accountable owner / 90 days
2	Fraud Leadership and Governance	Close the material control weakness recorded for "Management owns fraud-risk decisions and control action".	The CEO must approve a fraud-risk RACI that gives management clear decision rights, action ownership and resource authority, while the Governing body / independent oversight or equivalent assurance function receives independent review reports and tracks overdue control action to closure.	CEO / Managing Director / 30 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
3	Continuous Improvement and Fraud Risk Monitoring	Close the material control weakness recorded for "The organisation periodically reviews its fraud risks and control environment".	The Risk / compliance accountable owner must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.	CEO / Managing Director / 90 days
4	Fraud Risk Identification	Close the material control weakness recorded for "The organisation has completed a structured fraud risk assessment within the past two years".	The Risk / compliance accountable owner must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.	CEO / Managing Director / 90 days
5	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "The organisation provides a confidential or anonymous channel for reporting suspected fraud or misconduct".	The ethics owner operates a web/telephone channel available to the full defined population, assigns case IDs without exposing reporter identity, limits case access by role, routes allegations away from implicated managers, acknowledges reports within two business days and reports retaliation concerns directly to the Governing body / independent oversight.	Governing body / independent oversight / CEO / 60 days
6	Fraud Detection Capability	Close the material control weakness recorded for "Exception reporting provides defined alerts for unusual transactions or activities and a documented review process".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance / operations accountable owner / 60 days
7	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Employees know how to recognise suspected fraud and use the reporting channel".	The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.	People / workforce accountable owner / 60 days
8	Continuous Improvement and Fraud Risk Monitoring	Close the material control weakness recorded for "Fraud incidents or control failures are analysed to understand root causes and control weaknesses".	The Risk / compliance accountable owner must apply a structured root-cause method to every material incident and significant near-miss, classifying each cause as control absent, control designed but not operating, control operating but ineffective, or deliberate override, and identifying why detection was delayed; findings are recorded in a common register, aggregated at least twice a year to surface recurring themes across cases, and themes drive programme-level action rather than case-level fixes alone.	Finance / operations accountable owner / Risk / compliance accountable owner / 60 days
9	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud and control misuse by people inside the organisation".	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance / operations accountable owner / Technology / security accountable owner / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
10	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud threats from external parties relevant to the organisation".	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
11	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Relevant external stakeholders have an appropriate way to report suspected fraud or misconduct".	The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	Governing body / independent oversight / CEO / 60 days
12	Fraud Leadership and Governance	Close the material control weakness recorded for "Fraud risk is recognised in the organisation's wider risk or governance framework".	The Risk / compliance accountable owner must add fraud as a standing entry in the enterprise risk register with a named owner, documented inherent and residual ratings, explicit linkage to the fraud controls relied upon, an agreed risk-appetite statement and a scheduled reassessment date; any rating change requires written rationale retained with the register.	CEO / Managing Director / 30 days
13	Fraud Leadership and Governance	Close the material control weakness recorded for "Written guidance sets out how fraud should be prevented and detected, and how suspected fraud should be reported and handled".	The fraud-risk executive must maintain an approved fraud policy plus procedures covering prohibited conduct, prevention and detection duties by role, reporting routes, investigation and evidence handling, and disciplinary and recovery consequences; each document carries a version, approval date, owner and review date, is published where the whole workforce can reach it, and is reviewed at least every two years or after a material incident.	CEO / Managing Director / 60 days
14	Fraud Risk Identification	Close the material control weakness recorded for "Fraud risks linked to suppliers, contractors, agents, intermediaries or other third parties have been assessed".	The vendor-risk owner must maintain a third-party inventory segmented by relationship type and risk tier, assess fraud scenarios per tier including collusion with employees, substitution of goods or personnel, over-billing, impersonation and misuse of delegated authority or access, map the controls relied upon per tier, and record residual gaps in the treatment plan; the assessment refreshes when the third-party population or delegated authority changes materially.	Finance / operations accountable owner / 90 days
15	Operational Fraud Controls	Close the material control weakness recorded for "Transactions or operational activities above defined risk or value thresholds require independent review or approval".	The Finance / operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance / operations accountable owner / 60 days
16	Operational Fraud Controls	Close the material control weakness recorded for "Refunds, credits, write-offs, stock adjustments, manual journals and overrides receive independent review where used".	Finance and operations owners must extract the complete population of manual adjustments each period, require a mandatory reason code and supporting justification at capture, and have an independent reviewer outside the originating team examine all items above a risk threshold plus a random sample below it; repeat originators, round-value patterns and adjustments reversing prior-period entries are escalated to the Finance / operations accountable owner.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
17	Fraud Detection Capability	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Risk / compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Governing body / independent oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk / compliance accountable owner / 30 days
18	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The Governing body / independent oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Governing body / independent oversight / 90 days
19	Fraud Incident Response	Close the material control weakness recorded for "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure".	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Finance / operations accountable owner / Legal / investigations accountable owner / 30 days
20	Fraud Incident Response	Close the material control weakness recorded for "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal / investigations accountable owner / Finance / operations accountable owner / 60 days
21	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Reports submitted through the channel are reviewed independently from the people or teams implicated".	The ethics owner must apply documented routing rules at intake that identify implicated parties, exclude them and their direct reporting line from case access and decision-making, and route reports naming executives or the fraud-risk executive directly to the Governing body / independent oversight; case-management access is role-restricted and logged, routing decisions are recorded per case, and conflicts discovered later trigger immediate reassignment.	Governing body / independent oversight / 60 days
22	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism".	The procurement owner must require, above defined thresholds, that evaluation criteria and weightings are fixed and recorded before submissions are opened, submissions remain sealed until a scheduled opening witnessed by at least two people, evaluation is performed by a panel with signed conflict declarations, and single-source or emergency awards require documented justification and independent approval; a periodic analysis reviews award concentration, repeated near-identical pricing and rotating winners.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
23	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "High-risk suppliers or third-party relationships are periodically monitored or reviewed".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance / operations accountable owner.	Finance / operations accountable owner / 90 days
24	Operational Fraud Controls	Close the material control weakness recorded for "Operational processes are periodically reviewed to identify control weaknesses or opportunities for manipulation".	The Risk / compliance accountable owner must schedule reviews of material processes on a defined cycle, walk the process as actually performed including workarounds and manual steps, test a sample of transactions end to end, log identified weaknesses with an owner and due date, and report closure status to the fraud reporting forum; reviews prioritise processes with recent incidents, high manual intervention or recent change.	Finance / operations accountable owner / 90 days
25	Operational Fraud Controls	Close the material control weakness recorded for "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls".	Human Resources and the Risk / compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Finance / operations accountable owner / People / workforce accountable owner / 90 days
26	Operational Fraud Controls	Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance / operations accountable owner / People / workforce accountable owner / 60 days
27	Operational Fraud Controls	Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance / operations accountable owner / 60 days
28	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are updated when new fraud risks, fraud methods or operational changes emerge".	The monitoring owner must reassess the detection set whenever a new fraud method is identified internally or externally, a material process or system changes, or a confirmed incident bypassed existing detection; each change is documented with rationale, tested against historical data before deployment, version-controlled, and reported with before-and-after coverage to the management fraud-risk review route.	Finance / operations accountable owner / 90 days
29	Fraud Incident Response	Close the material control weakness recorded for "Fraud investigations follow documented procedures that protect confidentiality and fair treatment and record key facts, decisions and actions".	The investigation lead must use a controlled procedure and case template covering scope, facts, interview and evidence decisions, confidentiality, fair treatment, actions, escalation, recovery or disciplinary referrals and closure rationale; Legal or an independent reviewer challenges material cases before closure.	Legal / investigations accountable owner / Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
30	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "The organisation clearly communicates that retaliation against whistleblowers or people who raise concerns is prohibited".	The People / workforce accountable owner must issue a written anti-retaliation commitment covering employees, contractors and, where relevant, suppliers; communicate it alongside every reporting-channel message; monitor employment outcomes for identified reporters for a defined period after a report including performance action, transfer, roster change and termination; provide a direct route to the Governing body / independent oversight for retaliation concerns; and apply disciplinary consequences where retaliation is substantiated.	People / workforce accountable owner / Governing body / independent oversight / 30 days
31	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Employees are required to disclose and manage conflicts of interest involving suppliers or third parties".	The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.	Finance / operations accountable owner / Legal / investigations accountable owner / 60 days
32	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Procurement or vendor-management activity is subject to oversight or periodic review".	The Governing body / independent oversight must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	Governing body / independent oversight / Finance / operations accountable owner / 90 days
33	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance / operations accountable owner / 90 days
34	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Employees receive training on phishing, social engineering and digital impersonation attempts".	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Technology / security accountable owner / People / workforce accountable owner / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
35	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Employees and users know how to report suspicious digital activity or account-security concerns".	The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	Technology / security accountable owner / 60 days
36	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Emerging digital fraud risks relevant to the organisation's operations or sector are reviewed periodically".	The information security and digital owners must jointly run a periodic review of emerging digital fraud methods relevant to the organisation's channels, drawing on vendor and industry advisories, incident experience and peer reporting; each method is assessed against current preventive and detective controls, gaps become owned actions with due dates, and accepted risks are recorded with rationale and reported to the risk forum.	Technology / security accountable owner / 90 days

E2. Definitions and score basis

How the score is calculated

Each applicable assessment response is normalised to a 0–100 control score and weighted within its domain. Domain scores are then combined using the methodology's domain weights to produce the overall readiness score. A control recorded as not applicable is excluded from its scoring denominator rather than treated as a weakness.

The weighted overall score is 30.12/100, which maps numerically to Reactive. The final maturity shown in this report is Reactive. The next numerical band begins at 40/100; a higher numerical score alone does not override a stricter applicable maturity ceiling.

Maturity scale

MATURITY	SCORE RANGE	INTERPRETATION
Reactive	0–<40	Foundational controls are limited or mainly reactive.
Developing	40–<60	Core control elements exist but are incomplete, inconsistent or not yet connected.
Structured	60–<80	Controls are more consistently defined, owned and operated.
Strategic	80–100	Fraud-risk management is embedded, monitored and continually improved.

Maturity ceilings

Maturity ceilings protect against a strong average masking a material weakness. A hard-gate critical control scored 0 or 1 sets a maximum of Developing; a hard-gate control scored 2 sets a maximum of Structured; three or more critical controls scored 0, 1 or 2 set a maximum of Developing; any core domain below 40 sets a maximum of Developing; and any core domain below 60 sets a maximum of Structured. Where several ceilings apply, the strictest ceiling governs the final maturity.

Reported domain scores

DOMAIN	REPORTED SCORE	MATURITY
Fraud Leadership and Governance	22/100	Reactive
Fraud Risk Identification	22/100	Reactive
Operational Fraud Controls	41/100	Developing
Fraud Detection Capability	21/100	Reactive
Fraud Incident Response	24/100	Reactive
Whistleblowing and Reporting Culture	21/100	Reactive
Third-Party and Supply Chain Fraud Risk	42/100	Developing
Digital and Identity Fraud Risk	46/100	Developing
Fraud Culture and Awareness	37/100	Reactive
Continuous Improvement and Fraud Risk Monitoring	21/100	Reactive

Risk priority uses the MK qualitative likelihood/impact matrix. Risks in the same priority class are not further ranked by their display sequence. Priority and materiality are derived from assessment evidence; neither is an independent risk assessment.